

Website Vulnerability Scanner Report

✓ <https://brins.co.id/>

Target added due to a redirect from <https://brins.co.id>

Summary

Overall risk level:

Medium

Risk ratings:

Critical:	0
High:	0
Medium:	3
Low:	6
Info:	0

Scan information:

Start time:	May 07, 2026 / 10:01:10 UTC+07
Finish time:	May 07, 2026 / 10:04:47 UTC+07
Scan duration:	3 min, 37 sec
Tests performed:	40
VPN Profile:	Scan Internal
Scan status:	Finished

Findings

Insecure cookie setting: domain too loose

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
https://brins.co.id/	TS0125a1bb	Set-Cookie: .brins.co.id Request / Response

▼ Details

Risk description:

The risk is that a cookie set for example.com may be sent along with the requests sent to dev.example.com, calendar.example.com, hostedsite.example.com. Potentially risky websites under your main domain may access those cookies and use the victim session from the main site.

Recommendation:

The **Domain** attribute should be set to the origin host to limit the scope to that particular server. For example if the application resides on server app.mysite.com, then it should be set to **Domain=app.mysite.com**

Classification:

CWE : [CWE-614](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Insecure cookie setting: missing HttpOnly flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
-----	-------------	----------

https://brins.co.id/	domain, TSaebfa744029, TS379c2491027, TS0125a1bb	The server responded with Set-Cookie header(s) that does not specify the HttpOnly flag: Set-Cookie: domain=.brins.co.id Set-Cookie: TSaebfa744029=08684aafdaab2800b35e20f4562396a362c6990422f1fe9947b8c9d1ed142217ba4cc677308265cf95bb57f675b5ba6f Set-Cookie: TS379c2491027=08684aafdaab2000e6243b74c47ce0e46f501986eece6a3631b44d268d5ae3094383e89b6c635d8608650393d9113000f0beec490db3e5dfa8940767f380192b170b66e5fbab36564cf13d377922919ceca14c9e266cae55c6d2f375dfb05255 Set-Cookie: TS0125a1bb=01ea294f365950d9eb871d0b7f239b0e4b0b0d8a78a40b8c57d30923099433d61ada417bf401095c89a59d48c88ad7b6ff8d57dc40ed7b651ff9b3a65aa50bede2c177443e82c542049f8e73511cc3328eb13c1ee0 Request / Response
---	---	--

▼ Details

Risk description:

The risk is that an attacker who injects malicious JavaScript code on the page (e.g. by using an XSS attack) can access the cookie and can send it to another site. In case of a session cookie, this could lead to session hijacking.

Recommendation:

Ensure that the HttpOnly flag is set for all cookies.

References:

<https://owasp.org/www-community/HttpOnly>

Classification:

CWE : [CWE-1004](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Insecure cookie setting: missing Secure flag

CONFIRMED

port 443/tcp

URL	Cookie Name	Evidence
https://brins.co.id/	domain, TSaebfa744029, TS379c2491027, TS0125a1bb	Set-Cookie: domain=.brins.co.id Set-Cookie: TSaebfa744029=08684aafdaab2800b35e20f4562396a362c6990422f1fe9947b8c9d1ed142217ba4cc677308265cf95bb57f675b5ba6f Set-Cookie: TS379c2491027=08684aafdaab2000e6243b74c47ce0e46f501986eece6a3631b44d268d5ae3094383e89b6c635d8608650393d9113000f0beec490db3e5dfa8940767f380192b170b66e5fbab36564cf13d377922919ceca14c9e266cae55c6d2f375dfb05255 Set-Cookie: TS0125a1bb=01ea294f365950d9eb871d0b7f239b0e4b0b0d8a78a40b8c57d30923099433d61ada417bf401095c89a59d48c88ad7b6ff8d57dc40ed7b651ff9b3a65aa50bede2c177443e82c542049f8e73511cc3328eb13c1ee0 Request / Response

▼ Details

Risk description:

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : [CWE-614](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

Unsafe security header: Content-Security-Policy

port 443/tcp

CONFIRMED

URL	Evidence
https://brins.co.id/	Response headers include the HTTP Content-Security-Policy security header with the following security issues: <pre>script-src: 'unsafe-inline' allows the execution of unsafe in-page scripts and event handlers. script-src: data: URI in script-src allows the execution of unsafe scripts. frame-ancestors: This directive tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. The recommended value is 'none' or 'self'. script-src: 'unsafe-eval' allows the execution of code injected into DOM APIs such as eval(). script-src: https: URI in script-src allows the execution of unsafe scripts. object-src: We recommend restricting object-src to 'none'. script-src: 'self' can be problematic if you host JSONP, Angular or user uploaded files.</pre> Request / Response

Details

Risk description:

For example, if the unsafe-inline directive is present in the CSP header, the execution of inline scripts and event handlers is allowed. This can be exploited by an attacker to execute arbitrary JavaScript code in the context of the vulnerable application.

Recommendation:

Remove the unsafe values from the directives, adopt nonces or hashes for safer inclusion of inline scripts if they are needed, and explicitly define the sources from which scripts, styles, images or other resources can be loaded.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Missing security header: X-Content-Type-Options

port 443/tcp

CONFIRMED

URL	Evidence
https://brins.co.id/assets	Response headers do not include the X-Content-Type-Options HTTP security header Request / Response

Details

Risk description:

The risk is that lack of this header could make possible attacks such as Cross-Site Scripting or phishing in Internet Explorer browsers.

Recommendation:

We recommend setting the X-Content-Type-Options header such as `X-Content-Type-Options: nosniff`.

References:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>

Classification:

CWE : [CWE-693](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Missing security header: Referrer-Policy

port 443/tcp

CONFIRMED

URL	Evidence
https://brins.co.id/assets	Response headers do not include the Referrer-Policy HTTP security header as well as the <meta> tag with name 'referrer' is not present in the response. Request / Response

▼ Details

Risk description:

The risk is that if a user visits a web page (e.g. "http://example.com/pricing/") and clicks on a link from that page going to e.g. "https://www.google.com", the browser will send to Google the full originating URL in the **Referer** header, assuming the Referrer-Policy header is not set. The originating URL could be considered sensitive information and it could be used for user tracking.

Recommendation:

The Referrer-Policy header should be configured on the server side to avoid user tracking and inadvertent information leakage. The value **no-referrer** of this header instructs the browser to omit the Referer header entirely.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Missing security header: Content-Security-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://brins.co.id/assets	Response does not include the HTTP Content-Security-Policy security header or meta tag Request / Response

▼ Details

Risk description:

The risk is that if the target application is vulnerable to XSS, lack of this header makes it easily exploitable by attackers.

Recommendation:

Configure the Content-Security-Header to be sent with each HTTP response in order to apply the specific policies needed by the application.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Missing security header: Strict-Transport-Security

CONFIRMED

port 443/tcp

URL	Evidence
https://brins.co.id/assets	Response headers do not include the HTTP Strict-Transport-Security header Request / Response

▼ Details

Risk description:

The risk is that lack of this header permits an attacker to force a victim user to initiate a clear-text HTTP connection to the server, thus opening the possibility to eavesdrop on the network traffic and extract sensitive information (e.g. session cookies).

Recommendation:

The Strict-Transport-Security HTTP header should be sent with each HTTPS response. The syntax is as follows:

Strict-Transport-Security: max-age=<seconds>[; includeSubDomains]

The parameter `max-age` gives the time frame for requirement of HTTPS in seconds and should be chosen quite high, e.g. several months. A value below 7776000 is considered as too low by this scanner check.
The flag `includeSubDomains` defines that the policy applies also for sub domains of the sender of the response.

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Server software and technology found

UNCONFIRMED ⓘ

port 443/tcp

Software / Version	Category
 Amazon Web Services	PaaS
 MySQL	Databases
 PHP	Programming languages
 Sectigo	SSL/TLS certificate authorities
 DoubleClick Floodlight	Advertising
 WordPress	CMS, Blogs
 Format	CMS
 HSTS	Security

Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Scan coverage information

List of tests performed (40)

Port 443

- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for Secure flag of cookie
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for website technologies
- ✓ Scanned for unsafe HTTP header Content Security Policy

- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for client access policies
- ✓ Scanned for robots.txt file
- ✓ Scanned for absence of the security.txt file
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for code comments
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for internal error code
- ✓ Scanned for login interfaces
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Path Disclosure
- ✓ Scanned for Session Token in URL
- ✓ Scanned for API endpoints
- ✓ Scanned for emails
- ✓ Scanned for missing HTTP header - Rate Limit
- ✓ Scanned for PEM-encoded private key material
- ✓ Scanned for partial PEM-encoded private key material

Scan parameters

target:	https://brins.co.id/
scan_type:	Light
authentication:	False

Scan stats

Unique Injection Points Detected:	26
URLs spidered:	8
Total number of HTTP requests:	25
Average time until a response was received:	934ms